



THE 2000 SSH1 EXPLOIT THAT BROKE THE INTERNET



THE 2000 SSH1 EXPLOIT THAT BROKE THE INTERNET

AUTHORS: lcamtuf, scut, dvorak, scrippie, portal, gera, skyper

The 2000 SSH1 CRC32 RCE - CVE-2001-0144

This is the inside story of the ultimate exploit: one that allowed its wielder to get ROOT on most of the Internet.

"Every server was vulnerable. Remote, pre-auth, instant-root on all default-installs - the four words of the apocalypse."

-- unknown

...and how hackers' gallantry and etiquette prevented wider damage.

...written by the hackers who found the vulnerability and wrote the exploit.

```
$ ./sshexp 1.2.3.4 -t 0
linux/x86 sshd1 exploit by zip/TES0
(zip@james.kalifornia.com) - ripped from openssh
2.2.0 src

greet: mray, random, big t, sh1fty, scut, dvorak

ps. this sploit already owned cia.gov :/

.....

bruteforced distance: 0x3200

bruteforcing distance from h->partial packet
buffer on stack

.....^[[A.....|////////\\!

bruteforced h->ident buff distance: 5bfbed88

trying retloc_delta: 35

....!

found high words of possible return address: 808

trying to exploit

....

trying retloc_delta: 37

.!
```

1998 - HOW TO ADD A VULNERABILITY TO SSH

In the late 1990s, SSH was rather new. System administrators were still contemplating whether they should drop Telnet in favour of SSH. Then, in 1998, CoreSDI found a vulnerability in the SSH1 protocol: a minor bug and not an RCE [#1].

CoreSDI created a patch and sent it to Tatu Ylonen, the inventor of the Secure Shell. The patch added a function called "detect_attack()" to fix the vulnerability but the SSH maintainers made a fatal change to the original patch:

```
- static uint32_t n = HASH_MINSIZE /
HASH_ENTRY_SIZE;

+ static word16 n = HASH_MINSIZE / HASH_ENTRY_SIZE;
```

This broke the Internet.

A fix to an earlier bug introduced a worse vulnerability.

Cisco, OpenSSH and many others merged Tatu's patch into their source tree. The vulnerability spread. Nobody checked. Nobody noticed. (27 years later, Phrack Staff prophiled Gera, co-founder of CoreSDI [#2].)

2000 - LCAMTUF CRASHES SSH

Fast-forwarding to 2000: SSH was the new Telnet. The vulnerable SSH patch was now widely deployed across the Internet. A talented young hacker by the name of "lcamtuf" (from dione.ids.pl, the famous Polish shell-site for like-minded hackers) was working on the first fuzzing tool (the predecessor of the original American Fuzzy Lop, aka "AFL").

He runs it against SSH ... and SSH immediately crashes.

The hacker later became better known as Michal Zalewski.



THE 2000 SSH1 EXPLOIT THAT BROKE THE INTERNET

THE ONLY AVAILABLE DISCLOSURE

In 2000, the security industry was in its infancy (#non-existing or #lame).

Michal Zalewski was already working at BindView's RAZOR team at the time but vulnerabilities were discussed on IRC (where else?), in private groups, and among like-minded hackers. It was Stealth and Teso-adjacent circles that first saw the potential of this "beautiful" bug.

Various researchers started working on an exploit before the vulnerability was officially fixed.

"The crc32 exploit was particularly difficult. You had to brute the correct offsets and the shellcode had to survive the crc32 check."

-- scut

There was in-depth collaboration among these groups. The very first PoC was done by scut/team-teso (7350communicate). It overwrote the 16 most significant bits of the 32-bit return address. The connect-back shell code had to be split into multiple chunks.

Eventually, dvorak/synnergy found a way to stop the "loop" and survive the crc32 check (aka "the minefield"). This was a major improvement as it allowed for longer and continuous shell-code: A 64k nop sled to land in (more reliable), followed by a shell code that would drop straight into /bin/sh.

A friend of dvorak named this exploit the "x2".

The source code was only shared with a select few. However, the pre-compiled ELF binary of the exploit was more widely shared with fellow hackers.

The source code of the early alpha version and the final x2 source code have now been published for the first time [3]:

<https://github.com/hackerschoice/team-teso/tree/main/exploits/ssh-crc32>

The exploit needed precise offsets to work. Each combination of Linux distribution and SSH version required a different set of offsets.

"The offsets became a tradeable asset."

We traded offsets. A good list of working offsets was more valuable than the x2 exploit itself.

Later, dvorak added offset.sh, a script that would get the offsets automatically and mail them back to him. It was supposed to be run on the target but many hackers ran it on their workstation first.

The exploit was later modified to work against BSD and Solaris (but never publicly released).

TECHNICAL

(I keep this short and only what's historically relevant)

- There was no ASLR ("the good old times").
- The heap was always at the same base address (on a given system).
- For the exploit to work, SSH needed to receive the entire payload via a single syscall. TCP Fragmentation was used to "stuff the remote TCP buffer" before the final fragment "pushed" one huge motherlode of a payload to the SSH daemon process. As far as we know, this was the first time this trick has been used.
- Some brute forcing still needed to be done. It caused the SSHD to crash and restart. Normally, not a problem unless you were targeting systems running the grsecurity hardened Linux kernel (crashing services is an indicator of an attack - so grsec stopped the service before the exploit worked).
- It was a complex puzzle: The exploit overwrote data before the vulnerable function returned (i.e. before the shellcode could run). We nick-named it the "Minefield": The payload/shellcode had to survive the crc32 check.

(iirc, a combination of brute force & educated guesses was used).



THE 2000 SSH1 EXPLOIT THAT BROKE THE INTERNET

FIXES

The vulnerability was finally fixed in November 2000 with the release of OpenSSH 2.3.0.

The first advisory was published four months later, on the 8th of February 2001 [#4][#5]. Most servers did not update OpenSSH and the Internet remained vulnerable for many months (and years).

Team-Teso released a statement in April 2001 [#9], trying to caution the community.

By the time the Dutch hacker camp HAL2001 happened, the exploit was widely used.

The CERT finally releases VU#945216 in October 2001 [#6]. Followed by CA-2001-35 in December 2001, with a warning that the vulnerability was being exploited in the wild [#7][#8].

COMMERCIAL USE AND RUMOURS

Unfortunately, and much later, the x2 binary leaked to malicious hackers [#9]. Some x2 binaries were fake and others were infected with viruses. The virus would give the malicious hacker access to the workstation of whoever used it.

Eventually, one of those infected x2 binaries ended up in the hands of an early pen-testing @company.

One of their key employees uses the infected x2 ... and gets 0wned.

The employee's password was "whisk3yp1" - a reference to a b0ston cocktail bar called "Whiskey Park".

COMMENTS

- Notable are the many months that passed between discovery, vendor fix, advisory, and wider exploitation. These days this takes hours or weeks at most, and not months or years.
- There was no marketplace for exploits ("the good old times").
- The exploit developers were driven by intellectual stimulation to show their prowess, not by greed, criminal intent, or a political agenda.

- The unintended, widespread leak of the exploit and the resulting damage encouraged Team-Teso to develop "Burneye", the very first runtime ELF obfuscator. It locked the exploit binary to a single host so that it could not be copied or used by others.
- The SSH1-CRC32 attack became part of the SANS training courses [#10] and was also featured in the movie "Matrix Reloaded" [#11,#12], along with nmap.
- This bug contributed to the industry's push away from SSH1 toward SSH2.

SSH CRC32 REFERENCES

- [1] https://www.coresecurity.com/sites/default/files/private-files/publications/2016/05/KargiemanPacettiRicharte_1998-CRC32.pdf
- [2] Phrack Profile of Gera, co-founder of CoreSDI - <https://phrack.org/issues/72/2>
- [3] <https://github.com/hackerschoice/team-teso/tree/main/exploits/ssh-crc32>
- [4] CoreSDI - <https://marc.info/?l=bugtraq&m=98168366406903&w=2>
- [5] Bindview - https://web.archive.org/web/20010213194623/http://razor.bindview.com/publish/advisories/adv_ssh1crc.html
- [6] <https://www.kb.cert.org/vuls/id/945216>
- [7] <https://static.lwn.net/2001/1115/a/ssh-exploit.php3>
- [8] <https://static.lwn.net/2001/1220/a/CertOnSSH.php3>
- [9] https://web.archive.org/web/20040407040018/http://www.team-teso.net/sshd_statement.php
- [10] <https://www.giac.org/paper/gcih/295/exploiting-ssh-crc32-compensation-attack-detector-vulnerability/103026>
- [11] https://www.reddit.com/r/MovieDetails/comments/7s2qem/matrix_reloaded_using_the_real_crc32_exploit_to/?rdt=52769
- [12] <https://nmap.org/movies/>